

CloudChain posture report

Scan demo-4199b86f9a | demo mode | 2026-08-04T07:53:54.402775+00:00

22

/ 100

GRADE F

77.5 points deducted from 100

Posture 22/100 (grade F). 77.5 points were deducted across four dimensions; privilege is the largest single contributor at -25.0. The grade is capped at F because a confirmed path to AdministratorAccess exists.

How the score was calculated

Exposure		21.2 / 25
Privilege		25.0 / 25
Reachability		24.0 / 30
Blast radius		7.3 / 20

Dimension	Deducted	What it measured
Exposure	21.25 / 25	10 internet-reachable finding(s) totalling 51 severity pressure.
Privilege	25.00 / 25	9 identity weakness(es) totalling 43 privilege pressure.
Reachability	24.00 / 30	2 confirmed path(s) to AdministratorAccess; shortest is 3 hop(s); 1 cross an account boundary.
Blast radius	7.27 / 20	4 of 11 resources (36%) are reachable from an exposed entry point.

Accounts scanned

Account	Name	Findings
111111111111	prod	15
222222222222	shared-services	5
333333333333	sandbox	2

Findings by severity



Attack paths

Routes an unauthenticated attacker can walk, from an internet entry point to AdministratorAccess.

CRITICAL

1. A publicly exposed object in s3_bucket 'public-uploads-bucket' in prod leaks credentials for iam_user 'svc-deploy-bot' in prod
2. iam_user 'svc-deploy-bot' in prod holds iam:PassRole and can pass the role iam_role 'LambdaExecutionAdminRole' in prod into a new Lambda function or EC2 instance, then invoke/run it
3. iam_role 'LambdaExecutionAdminRole' in prod is granted AdministratorAccess (AdministratorAccess in prod)

CRITICAL | crosses 111111111111, 222222222222

1. A publicly exposed object in s3_bucket 'public-uploads-bucket' in prod leaks credentials for iam_user 'svc-deploy-bot' in prod
2. iam_user 'svc-deploy-bot' in prod is named in the trust policy of iam_role 'OrgDeploymentRole' in shared-services and can cross the account boundary with sts:AssumeRole
3. iam_role 'OrgDeploymentRole' in shared-services is granted AdministratorAccess (AdministratorAccess in shared-services)

Escalation routes

Routes that open once the starting identity is compromised. Latent privilege-escalation primitives, not live breach routes.

CRITICAL

1. iam_user 'svc-deploy-bot' in prod holds iam:PassRole and can pass the role iam_role 'LambdaExecutionAdminRole' in prod into a new Lambda function or EC2 instance, then invoke/run it
2. iam_role 'LambdaExecutionAdminRole' in prod is granted AdministratorAccess (AdministratorAccess in prod)

CRITICAL | crosses 111111111111, 222222222222

1. iam_user 'svc-deploy-bot' in prod is named in the trust policy of iam_role 'OrgDeploymentRole' in shared-services and can cross the account boundary with sts:AssumeRole
2. iam_role 'OrgDeploymentRole' in shared-services is granted AdministratorAccess (AdministratorAccess in shared-services)

All findings (22)

#	Score	Severity	Issue	Resource
1	56.25	CRITICAL	S3_SENSITIVE_OBJECT_EXPOSED	public-uploads-bucket
2	37.5	CRITICAL	IAM_CROSS_ACCOUNT_TRUST	OrgDeploymentRole
3	25.0	CRITICAL	IAM_PRIVILEGE_ESCALATION_RISK	svc-deploy-bot
4	22.5	HIGH	S3_PUBLIC_ACCESS	public-uploads-bucket
5	22.5	HIGH	IAM_USER_NO_MFA	svc-deploy-bot
6	15.0	HIGH	IAM_ROLE_ADMIN_ACCESS	LambdaExecutionAdminRole
7	15.0	HIGH	IAM_ROLE_ADMIN_ACCESS	OrgDeploymentRole
8	11.25	MEDIUM	S3_NO_ENCRYPTION	public-uploads-bucket
9	9.0	HIGH	S3_PUBLIC_ACCESS	app-assets-public
10	9.0	HIGH	IAM_USER_NO_MFA	legacy-ci-user
11	9.0	HIGH	SG_OPEN_TO_INTERNET	sg-0demo0webserver
12	9.0	HIGH	SG_OPEN_TO_INTERNET	sg-0demo0webserver
13	7.5	MEDIUM	IAM_STALE_ACCESS_KEY	svc-deploy-bot
14	3.75	LOW	S3_NO_VERSIONING	public-uploads-bucket
15	3.0	MEDIUM	S3_NO_ENCRYPTION	sandbox-scratch
16	3.0	MEDIUM	IAM_STALE_ACCESS_KEY	legacy-ci-user
17	3.0	MEDIUM	IAM_CROSS_ACCOUNT_TRUST	AuditReadOnlyRole
18	1.5	LOW	S3_AWS_OWNED_ENCRYPTION_KEY	app-assets-public
19	1.0	LOW	S3_NO_VERSIONING	sandbox-scratch

#	Score	Severity	Issue	Resource
20	1.0	LOW	IAM_WEAK_PASSWORD_POLICY	account
21	1.0	LOW	IAM_ROLE_ADMIN_ACCESS	OrganizationAccountAccessRole
22	1.0	LOW	IAM_CROSS_ACCOUNT_TRUST	OrganizationAccountAccessRole

Remediation

S3_SENSITIVE_OBJECT_EXPOSED on public-uploads-bucket

Rotate any credentials referenced by these objects immediately, remove them from the bucket, and make the bucket private.

IAM_CROSS_ACCOUNT_TRUST on OrgDeploymentRole

Scope the trust policy to the specific role that needs it, add an sts:ExternalId condition, and reduce the role's permissions to least privilege.

IAM_PRIVILEGE_ESCALATION_RISK on svc-deploy-bot

Scope iam:PassRole to specific role ARNs with a condition, and remove IAM write permissions this identity doesn't need.

S3_PUBLIC_ACCESS on public-uploads-bucket

Enable all four Block Public Access settings and remove public grants from the bucket ACL/policy.

IAM_USER_NO_MFA on svc-deploy-bot

Enforce MFA for this user (console) and prefer temporary credentials over long-lived access keys.

IAM_ROLE_ADMIN_ACCESS on LambdaExecutionAdminRole

Scope this role to only the permissions its workload requires.

IAM_ROLE_ADMIN_ACCESS on OrgDeploymentRole

Scope this role to only the permissions its workload requires.

S3_NO_ENCRYPTION on public-uploads-bucket

Enable default server-side encryption (SSE-S3 or SSE-KMS).

S3_PUBLIC_ACCESS on app-assets-public

Enable all four Block Public Access settings and remove public grants from the bucket ACL/policy.

IAM_USER_NO_MFA on legacy-ci-user

Enforce MFA for this user (console) and prefer temporary credentials over long-lived access keys.

SG_OPEN_TO_INTERNET on sg-0demo0webserver

Restrict this rule to specific trusted CIDR ranges or remove it entirely.

SG_OPEN_TO_INTERNET on sg-0demo0webserver

Restrict this rule to specific trusted CIDR ranges or remove it entirely.

IAM_STALE_ACCESS_KEY on svc-deploy-bot

Rotate or deactivate this access key.

S3_NO_VERSIONING on public-uploads-bucket

Enable versioning on the bucket.

S3_NO_ENCRYPTION on sandbox-scratch

Enable default server-side encryption (SSE-S3 or SSE-KMS).

IAM_STALE_ACCESS_KEY on legacy-ci-user

Rotate or deactivate this access key.

IAM_CROSS_ACCOUNT_TRUST on AuditReadOnlyRole

Scope the trust policy to the specific role that needs it, add an sts:ExternalId condition, and reduce the role's permissions to least privilege.

S3_AWS_OWNED_ENCRYPTION_KEY on app-assets-public

Switch this bucket to SSE-KMS with a customer-managed key, and enable an S3 Bucket Key to keep request costs down.

S3_NO_VERSIONING on sandbox-scratch

Enable versioning on the bucket.

IAM_WEAK_PASSWORD_POLICY on account

Require a minimum length of 14+ with symbols, numbers, and mixed case.

IAM_ROLE_ADMIN_ACCESS on OrganizationAccountAccessRole

No action required unless this role should not exist. Verify the account it trusts is your own organisation management account.

IAM_CROSS_ACCOUNT_TRUST on OrganizationAccountAccessRole

Confirm that 999999999999 is an account you recognise. If it isn't, treat this as urgent.

Generated by CloudChain. Every number in this report is derived from the same scan result the dashboard renders.